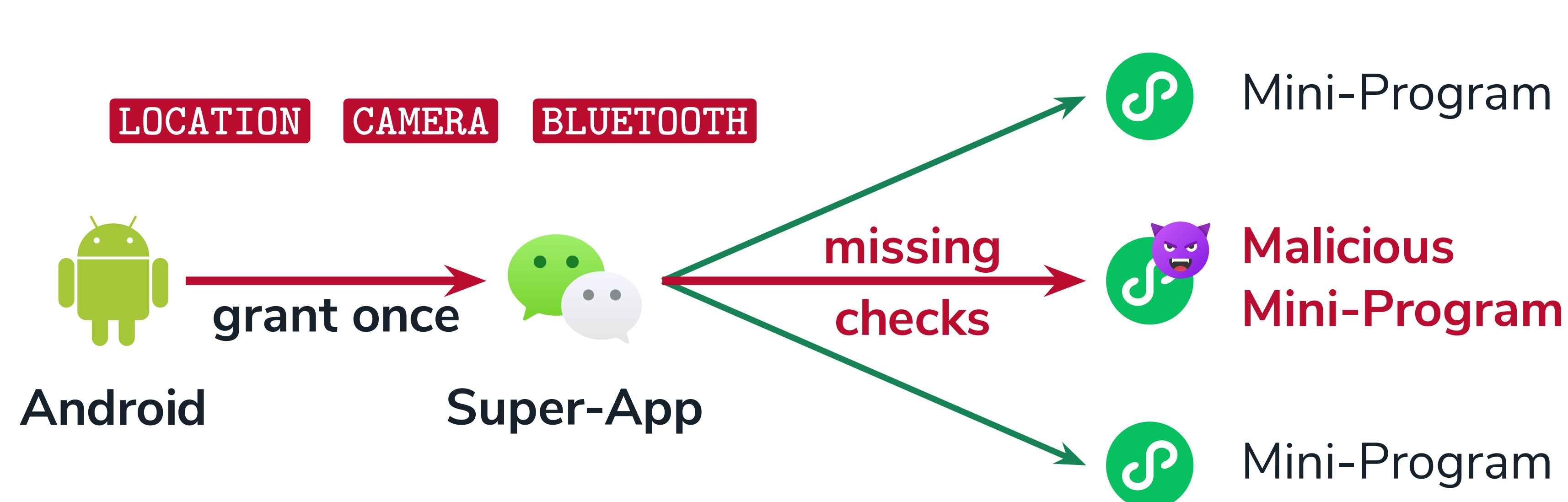


Raising the Flag: Detecting Missing Permission Controls in Mini-Program APIs

Zhiao Wei^{*†}, Chao Wang^{*‡}, Haseeb-Ur-Rehman Faheem[†],
Luyi Xing[§], Yousra Aafer[†], Zhiqiang Lin[‡]
[†]University of Waterloo [‡]The Ohio State University [§]University of Illinois Urbana-Champaign
^{*}Equal contribution

Android's permission model breaks inside Super-Apps

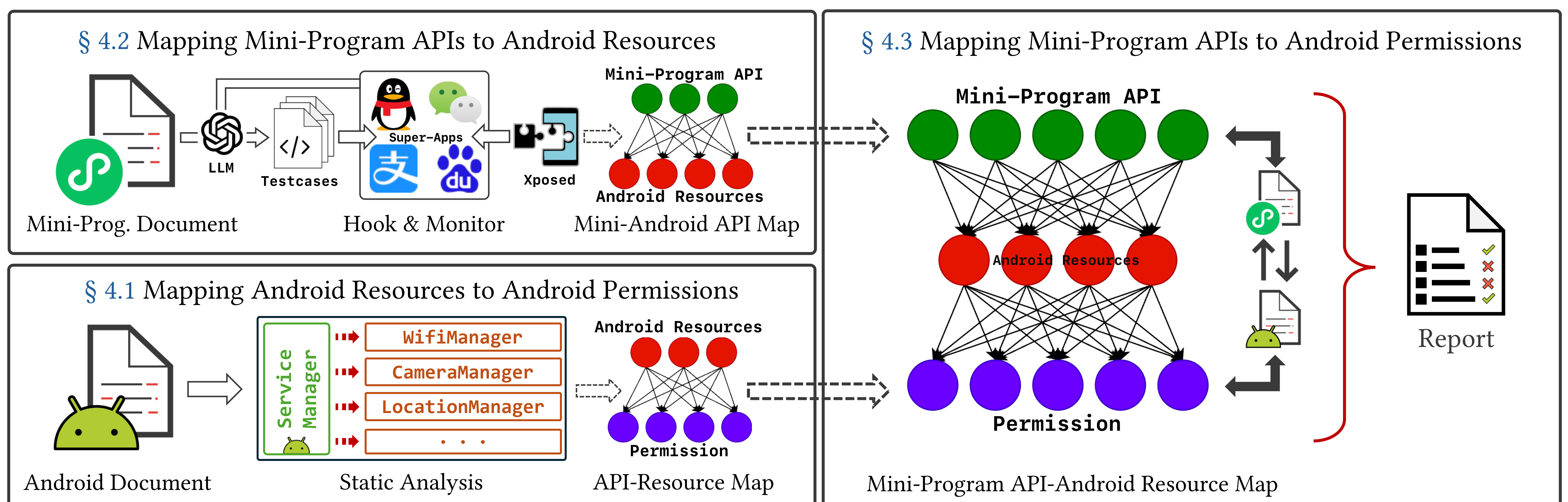
One host permission grant silently serves every Mini-Program.



180 Android permissions vs. **≤ 14** scopes per Super-App

1. Android sees the host, not the caller.
2. Scopes restore per-Mini-Program consent.
3. A missing check becomes a privilege bridge.

PermScope makes permission inheritance visible



- 1 LLM-generated valid API calls
- 2 Cross-process + async tracing
- 3 Map reached permissions to scopes

Three ways consent breaks

Ecosystem-wide gaps

One unchecked API is enough

35 **Partial enforcement**
A scope covers only some permissions an API reaches.

46 **No enforcement**
A relevant scope exists, but the API never checks it.

102 **No definition**
No scope exists for the protected resource.

258 APIs reach protected Android resources
Only **75** enforce an aligned scope

183 / 2,067
APIs lack proper permission checks
8.85% across 4 major platforms

WeChat **96**
Alipay **43**
Baidu **33**
QQ **11**

81 dangerous-level
102 normal-level



Wi-Fi scan ⇒ user location
my.getWifiList() reaches location-protected scan results, w/o a location scope prompt.



Fingerprint prompt ⇒ phishing
wx.startSoterAuthentication() reaches the fingerprint sensor w/ no Mini-Program scope.

Vendors acknowledged the reports and fixed key issues

Enforce consent at the Mini-Program API boundary.



Contact
wang.15147@osu.edu



Artifact
github.com/OSUSecLab/PermScope